USDT0 · SECURITY REVIEW

USDT0
XAUT0 BSC Deployment.

A security review of XAUT0 BSC Deployment.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
USDT0	XAUT0 BSC Deployment	Minato7namikazi	March 25 – March 31, 2026	March 31, 2026

§ 00

Contents.

11 pages: overview, confidence ranking, scope, 1 finding, disclaimer, and about Guardian.

§ 01 Overview P. 03

§ 02 Confidence Ranking P. 04

§ 03 Scope & Classifications P. 05

§ 04 Findings P. 06

Main Review · 1 finding P. 07

§ 05 Disclaimer P. 10

§ 06 About Guardian P. 11

§ 01

Overview.

Guardian reviewed XAUT0 BSC Deployment across a single review round.
The final report includes 1 Low finding.

AUDIT FIRM
Guardian

CLIENT
USDT0

PROJECT
XAUT0 BSC Deployment

PREPARED BY
Minato7namikazi

AUDIT WINDOW
March 25 – March 31, 2026

FINAL REPORT
March 31, 2026

METHODOLOGY
Smart contract · Manual · Main Review

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer's assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	**0**	0	0	0	0
High	**0**	0	0	0	0
Medium	**0**	0	0	0	0
Low	**1**	1	0	0	0
Informational	**0**	0	0	0	0
All severities	**1**	**1**	**0**	**0**	**0**

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed XAUT0 BSC Deployment.

IN SCOPE

BSC (Chain ID: 56)

Contract Address

Token Proxy 0x21cAef8A43163Eea865baeE23b9C2E327696A3bf

Token Implementation 0x9151434b16b9763660705744891fa906f660ecc5

Token ProxyAdmin 0xedaba024be4d87974d5ab11c6dd586963cccb027

OFT Proxy 0x53C3A64c8942288e12813C1F8457Db45980BcfC2

OFT Implementation 0xded1660192d4d82e7c0b628ba556861edbb5cada

OFT ProxyAdmin 0x01bff41798a0bcf287b996046ca68b395dbc1071

Safe (Multisig) 0x4dff9b5b0143e642a3f63a5bcf2d1c328e600bf8

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH	Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.
IMPACT · MEDIUM	Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.
IMPACT · LOW	Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.
LIKELIHOOD · HIGH	Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.
LIKELIHOOD · MEDIUM	Possible only in uncommon cases or requires a large amount of capital relative to

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in. Status is where each finding ended up; its own page says how.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
L-01	Potential DoS via Unexecutable Inbound Message Queue	DoS	LOW	PENDING	p. 7

LOW L-01

PENDING

Potential DoS via Unexecutable Inbound Message Queue

CATEGORY	DoS
LOCATION	https://github.com/LayerZero-Labs/LayerZero-v2/blob/9c741e7f9790639537b1710a203bcdfd73b0b9ac/packages/layerzero-v2/evm/protocol/contracts/MessagingChannel.sol#L134
REVIEW	Main Review

DESCRIPTION

Upon successful receipt of inbound message hashes, the executor invokes `lzReceive`. During this process, LayerZero lazily updates the nonce within `_clearPayload`.

```javascript
if (_nonce > currentNonce) {
unchecked {
// try to lazily update the inboundNonce till the _nonce
for (uint64 i = currentNonce + 1; i <= _nonce; ++i) {
if (!_hasPayloadHash(_receiver, _srcEid, _sender, i)) revert Errors.LZ_InvalidNonce(i);
}
lazyInboundNonce[_receiver][_srcEid][_sender] = _nonce;
}
}
```

https://github.com/LayerZero-Labs/LayerZero-v2/blob/9c741e7f9790639537b1710a203bcdfd73b0b9ac/packages/layerzero-v2/evm/protocol/contracts/MessagingChannel.sol#L134

While updating the nonce, the protocol enforces that for a given message with nonce `n`, all messages with nonce `< n` must be at least *inbounded* (execution is not required). This validation is implemented via a loop.

If there is a long queue of inbounded messages prior to nonce `n`, the loop may become expensive in terms of gas.

Description:

One might assume that as earlier messages get executed (e.g., message 501 in a queue of 1000), the pressure on subsequent messages reduces. This assumption aligns with LayerZero's design, as noted in the code:

```solidity
```

L-01 Potential DoS via Unexecutable Inbound Message Queue CONTINUED

/// @dev if a lot of messages are queued, the messages can be cleared with a smaller step size to prevent OOG

```
However, this assumption breaks if the queued messages are **unexecutable**.
---
### Attack Scenario
An attacker can deliberately create a large number of inbounded but unexecutable messages, causing the loop to run out of gas when processing later messages.
This is feasible in OApps such as Tether (USDT), where:
- Cross-chain transfers to blacklisted addresses will revert on the destination chain.
- Transfers to certain contract addresses may also revert.
By repeatedly sending such transactions, an attacker can fill the inbound queue with messages that cannot be executed.
---
### Feasibility Analysis
At first glance, this may appear impractical due to high gas requirements (e.g., \~16M gas per transaction on EVM).
However, this overlooks executor behavior:
- Executors are only incentivized to spend the gas specified during message submission.
- If the configured gas limit is reasonable (e.g., 300k), an attacker would only need \~150 such failing messages to create a clog.
---
### Impact
This can temporarily block the processing of subsequent messages (i.e., a denial-of-service on the messaging channel).
However, this does **not** result in permanent blockage or loss of funds.
---
### Mitigation / Design Consideration
LayerZero provides a **skip mechanism**:
- OApp owners or delegates can call `skip` on the endpoint to manually advance the nonce.
- This clears the blockage and restores normal operation.
---
### Severity
This issue is **not Critical or High severity** because:
- No funds are lost.
- The blockage is temporary and can be resolved via `skip`.
```

However, it represents a **valid operational risk** that can disrupt message processing.

L-01 Potential DoS via Unexecutable Inbound Message Queue CONTINUED

RECOMMENDATION

Consider monitoring queued inbound messages on destination chains, detecting abnormal buildups of unexecutable messages, and proactively intervening using the `skip` function when necessary.

RESOLUTION

Status: Pending.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

$45B+
DIGITAL ASSETS UNDER REVIEW

200+
ENGAGEMENTS COMPLETED

500+
CRITICAL & HIGH FINDINGS REPORTED

Reach us at audits@guardianaudits.com.